STANDARD OPERATING PROCEDURE (SOP)

Deployment and Integration of Tenable Nessus Professional

SOP ID	SOC-VM-TEN-001	**Version**	1.0
Status	Draft	**Environment**	SOC.lab
Platform	Tenable Nessus Professional	**Department**	Security Engineering / SOC Operations
Owner	Security Engineering and Vulnerability Management	**Date**	2026-03-16

Review Procedure

This SOP will be reviewed quarterly, after any material change to scan scope, credential model, asset criticality definitions, or integrations with Wazuh, Splunk SOAR, or OpenEDR. It must also be reviewed after any major Tenable/Nessus version change or after repeated scan failures affecting critical assets.

1. Purpose

This SOP defines the standard process for deploying, configuring, and integrating Tenable Nessus Professional within SOC.lab as the vulnerability scanning and exposure-prioritization platform.

In SOC.lab, Tenable operates as a dedicated server-and-scanner platform inside the SOC stack. It provides credentialed vulnerability assessment, asset exposure context, server hardening visibility, and actionable data to improve analyst decisions in Wazuh, Splunk SOAR, and OpenEDR workflows.

The objectives of this SOP are to:

- Deploy a dedicated Nessus Professional scanning platform in a controlled SOC.lab location.
- Perform credentialed vulnerability scanning for approved Windows and Linux assets.
- Organize scan targets by operating system while adjusting operational priority by asset criticality.
- Provide vulnerability context to Wazuh for correlation and to SOAR for enrichment during investigations.
- Use Tenable findings to improve containment decisions in OpenEDR when endpoint alerts coincide with known exploitable exposure.
- Standardize scan cadence, validation, maintenance, and escalation handling.

2. Scope

This SOP applies to Tenable Nessus Professional deployment and integration activities in SOC.lab only.

- Dedicated Tenable server and scanner setup inside the SOC stack.
- Credentialed scanning for approved Windows and Linux assets.
- Coverage of endpoints, servers, virtualization infrastructure, security servers, and network devices where approved.
- Planned exclusion of the domain controller from routine Tenable scanning in the base deployment model.
- Integration with Wazuh for correlation and alert context.
- Integration with Splunk SOAR for enrichment during investigations.

- Use of Tenable context in OpenEDR containment decision logic.
- Validation, maintenance, troubleshooting, and service continuity.

This SOP does not authorize Tenable to perform direct remediation, modify architecture, or replace analyst judgement for final containment decisions.

3. Roles and Responsibilities

Role	Responsibility
Security Engineering	Owns Tenable deployment standards, scan policy design, credential strategy, and integration requirements.
SOC Engineering	Implements scanner configuration, target grouping, schedules, exports, and correlation integrations with Wazuh and SOAR.
SOC Analysts	Use Tenable findings as exposure context during alert review, prioritization, and escalation.
Endpoint / Platform Engineering	Provides approved credentials, validates impact on target systems, and resolves scan-side access issues.
Vulnerability Management Function	Tracks high-priority findings, retest activity, and remediation status when applicable.

4. Keywords and Definitions

Term	Definition
Tenable / Nessus Professional	Vulnerability scanning platform used in SOC.lab for credentialed discovery, exposure validation, and prioritization context.
Credentialed Scan	A scan that authenticates to the endpoint or server using approved credentials to produce deeper and more accurate findings.
Asset Criticality	The operational importance assigned to a system, used to raise or lower vulnerability handling priority.
Correlation	Use of Tenable findings alongside alerts from other tools such as Wazuh or OpenEDR to improve confidence and prioritization.
Retest	A scheduled or manual re-scan used to confirm whether a previously reported finding remains present.

5. Essential Business Functions

Tenable supports the following essential security operations functions in SOC.lab:

- Identify exploitable weaknesses before they are paired with live endpoint or network alerts.
- Provide vulnerability context to improve alert triage and severity handling.
- Supply server and endpoint exposure data to SOAR-driven enrichment workflows.
- Support OpenEDR containment decisions when suspicious activity occurs on exposed systems.
- Provide exportable reporting for security review and remediation tracking.

6. Procedures

6.1 Architecture and Security Preconditions

- Deploy Tenable Nessus Professional as a dedicated server-and-scanner platform inside the SOC stack.
- Ensure the Nessus host has a static address, approved DNS resolution, and restricted administrative access.
- Use domain-based credentials for credentialed scanning where approved. Local or alternate service credentials may be used only if domain credentials are not appropriate for the target class.
- Protect all scan credentials and API keys using approved credential storage and least-privilege access.
- Confirm that the domain controller remains excluded from the base scan scope unless a separately approved exception exists.

6.2 Scan Scope and Target Classes

The SOC.lab base scan scope includes all approved applicable assets, organized primarily by operating system.

Target Class	Default Inclusion	Credential Model	Notes
Windows Endpoints	Included where approved	Domain credentials	Use conservative credentials and monitor scan impact.
Windows Servers	Included	Domain credentials	High-value systems should be tagged by criticality.
Linux Servers	Included	Credentialed Linux access	Use approved secure authentication method for Linux targets.
Hyper-V Host	Included when approved	Credentialed	Treat as high criticality.
Security Servers	Included when approved	Credentialed	Coordinate with platform owners before first scan.
Network Devices	Included where supported	Device-specific	Use only approved safe checks.
Domain Controller	Excluded by default	N/A	Separate approval required before inclusion.

6.3 Server Installation and Base Configuration

1. Provision the dedicated Nessus server according to approved SOC.lab resource standards.
2. Install Nessus Professional using the licensed deployment package.
3. Apply initial hardening, set the administrative account, and validate secure console access.
4. Configure DNS, time synchronization, and outbound connectivity required for plugin/feed updates.
5. Enable automatic plugin/feed updates where approved, while keeping broader platform changes under internal change control.

6.4 Target Organization Model

Targets must be grouped first by operating system, then tagged or grouped further by asset criticality. This keeps scan policy logic simple while still allowing priority handling to reflect business importance.

- Windows endpoint groups
- Windows server groups
- Linux server groups

- High-criticality asset overlay
- Internet-exposed or forward-facing asset overlay where applicable

6.5 Credentialed Scan Configuration

6. Create and test credential objects for Windows and Linux scanning.
7. Use approved AD/domain credentials for Windows scanning where possible.
8. Validate that credentials permit meaningful local interrogation without granting unnecessary administrative reach beyond scan requirements.
9. Test credential success against representative sample hosts before full target rollout.
10. Document failed authentication patterns and resolve them before promoting scheduled scans.

6.6 Scan Scheduling Standard

Asset Class	Cadence	Default Mode	Operational Note
Endpoints	Weekly	Credentialed vulnerability scan	Use balanced timing to reduce user disruption.
Servers / Critical Infrastructure	Monthly	Credentialed vulnerability scan	Coordinate with owners for sensitive assets.
Retests	Scheduled re-scan	Validation	After remediation.

6.7 Severity and Prioritization Standard

SOC.lab does not rely on Tenable-native severity alone. Findings must be adjusted by asset criticality before operational priority is assigned.

- Base severity originates from Nessus findings.
- Priority is raised when the affected asset is high criticality.
- Priority is raised further when a live alert or investigation is already active for the same asset.
- A vulnerability tied to an active alert is treated as high-priority investigative context, even if the raw finding alone would not have triggered escalation.

6.8 Wazuh Integration

Wazuh should ingest Tenable findings for correlation rather than using Tenable only as a side reference.

11. Expose or export Nessus findings in a format usable by Wazuh-side ingestion or polling workflow.
12. Ensure Wazuh can associate the finding with the correct hostname, IP, and asset class.
13. Use Tenable findings to support correlation, not to replace live detection telemetry.
14. Validate that correlated events can show both vulnerability context and the original security signal.

6.9 Splunk SOAR Integration

SOAR must use Tenable primarily as an enrichment source.

15. During an investigation, SOAR should query Tenable for relevant vulnerability and exposure context.
16. SOAR should enrich alerts with known findings on the same asset when those findings are likely to affect risk or response priority.
17. If Tenable is unavailable, SOAR must continue without Tenable enrichment rather than blocking the entire workflow.

6.10 OpenEDR Relationship

OpenEDR uses Tenable context only to improve containment decision quality; it does not use Tenable as a replacement for endpoint evidence.

- If OpenEDR reports suspicious activity on an asset with relevant Tenable exposure, analysts may raise priority or accelerate containment review.
- Tenable context should influence containment logic when endpoint evidence and exposure align.
- Endpoint containment must still be based on analyst judgement and confirmed endpoint behavior.

6.11 Analyst Workflow

The default analyst workflow in SOC.lab is hybrid:

18. Review the vulnerability in Tenable to understand exposure detail and plugin evidence.
19. Promote or document operational follow-up in OpenEDR or the approved incident workflow when the finding affects an active security event.
20. Use Wazuh and SOAR views to correlate Tenable findings with live alerts before escalating containment decisions.

7. Troubleshooting Procedures

Issue	Required Checks
Credentialed scans fail	Validate domain credential scope, host reachability, local authentication permissions, and target-side service availability.
Target not discovered or not scanned	Confirm asset inclusion, IP accuracy, DNS resolution, routing, and scan policy membership.
Excessive impact on target systems	Reduce scan aggressiveness, narrow scan windows, and coordinate with the asset owner.
Wazuh does not show Tenable context	Validate export/polling path, field mapping, and hostname/IP normalization.
SOAR enrichment fails	Confirm API account validity, Tenable server reachability, and playbook-side error handling.

8. Validation and Acceptance Criteria

A Tenable deployment is not considered production-ready in SOC.lab until the following validation items are complete:

- Scanner is installed and reachable.
- Plugin/feed updates are functioning.
- Credentialed scans succeed against representative Windows and Linux targets.
- Findings appear correctly in Tenable with usable host context.
- Wazuh and SOAR can consume Tenable context where configured.
- Export/report functions work for analyst and engineering use.

Validation should be performed first against controlled representative systems before expanding to the broader approved scope.

9. Service Continuity

If Tenable becomes unavailable, analysts may use the last known vulnerability context where appropriate, but SOAR workflows must continue without blocking on Tenable enrichment. The security engineering team must be notified and vulnerability-based prioritization should be treated as degraded until service is restored.

10. Escalations

Condition	Primary Escalation	Secondary Escalation
Credential failure across multiple asset groups	Security Engineering	Platform / Identity Engineering
Tenable-to-Wazuh or SOAR integration failure	SOC Engineering	Security Engineering
Critical finding tied to active security alert	SOC Analysts	Security Engineering / Incident Lead
Scanner outage or failed update path	SOC Engineering	Infrastructure / Platform Owner

11. Record Management

- Retain scan results, exports, and analyst-relevant output according to the current SOC.lab retention rule.
- Document changes to scan scope, excluded assets, credential model, and schedules through internal change control.
- Preserve reports and exports required for engineering review, correlation validation, and remediation follow-up.

12. Maintenance

- Review scanner health and update status regularly.
- Confirm target groups remain accurate as assets change roles or operating systems.
- Review domain-controller exclusion status periodically.
- Review false positives or obsolete findings and refine scan policies where necessary.
- Validate scheduled re-scan behavior after remediation cycles.

13. Equipment, Hardware, and Software

- Dedicated Tenable Nessus Professional server
- Approved Windows and Linux target endpoints and servers
- Wazuh for correlation
- Splunk SOAR for enrichment workflows
- OpenEDR for containment decision context
- AD/domain credential source for Windows credentialed scans

14. Configuration

Baseline configuration decisions for SOC.lab:

- Product: Tenable Nessus Professional
- Deployment model: dedicated server + scanner
- Placement: inside SOC stack
- Scan mode: credentialed Windows and Linux scanning
- Grouping model: primarily by operating system
- Priority model: severity adjusted by asset criticality
- Endpoint exclusion: domain controller excluded from default scope
- Integrations: Wazuh correlation, SOAR enrichment, OpenEDR containment context

15. Change Control

All production changes to Tenable deployment, scan scope, credentials, schedules, target groups, exclusions, and integration settings must follow professional internal change control. Automatic plugin/feed updates are acceptable, but broader platform changes and scope changes require controlled review.

16. References

- SOC.lab topology and approved asset criticality model
- Wazuh integration standards
- Splunk SOAR workflow standards
- OpenEDR setup and integration standards

17. Approval

Role	Name	Date
Prepared by	Joshua Sartain	
Reviewed by	Engineering Team	
Approved by	Engineering Team	